

Authority for Personal Data
P.O. Box 93374, 2509 AJ The Hague
Hoge Nieuwstraat 8, 2514 EL The Hague
T 070 8888 500 - F 070 8888 501
autoriteitpersoonsgegevens.nl
The Minister of Justice and Security
Mrs. Drs. D. Yeşilgöz-Zegerius
P.O. Box 20301
2500 EH THE HAGUE

Date

June 20, 2024

Our reference

z2024-013712

Your letter dated

May 14, 2024

Contact person

Your reference

Subject

Legislative assessment of the draft bill Cybersecurity Act (NIS2)

Dear Mrs. Yeşilgöz,

In your letter dated May 14, 2024, the Authority for Personal Data (AP) was consulted pursuant to the provisions of Article 36, fourth paragraph, of the General Data Protection Regulation (GDPR), regarding the draft bill for the implementation of Directive (EU) 2022/2555 of the European Parliament and the Council of December 14, 2022, concerning measures for a high common level of cybersecurity in the Union, amending Regulation (EU) No. 910/2014 and Directive (EU) 2018/1972 and repealing Directive (EU) 2016/1148 (OJ EU 2022, L 333) (hereinafter: the draft).

The AP has several comments on the draft.

Main points

- The aim of the NIS2 directive is to bring unity and coherence to European policy on network and information security by increasing digital preparedness and reducing the impact of cyber incidents.
- To this end, the NIS2 directive, as well as the draft, distinguishes between essential entities and important entities, and imposes a duty of care, a reporting obligation, and an obligation to provide information.
- The draft designates a number of authorities responsible for the tasks mentioned in the draft, within which these authorities may process personal data.
- The draft is insufficiently clear about which personal data, including special categories of personal data, may be processed.
- Furthermore, the draft does not contain a retention period nor a delegation basis to establish rules regarding this in delegated legislation.
- Additionally, the enforcement powers of the AP are not correctly implemented in the draft.

Date

June 20, 2024

Our reference

z2024-013712

2/8

Scope of the draft

The draft aims to implement Directive (EU) 2022/2555 (hereinafter: NIS2 directive) into Dutch legislation. The goal of the NIS2 directive is to bring unity and coherence to European policy on

network and information security by increasing digital preparedness and reducing the impact of cyber incidents. To implement the NIS2 directive, the draft introduces a national register of entities, managed by the Minister of Justice and Security, in which essential entities, important entities, and entities providing domain name registration services must be included.² The draft contains a duty of care for essential and important entities to take appropriate and proportionate technical, operational, and organizational measures to manage risks to the security of the network and information systems they use.³ Furthermore, the draft includes several governance obligations for the members of the board of essential and important entities⁴ and introduces a reporting obligation for significant incidents.⁵ The draft also designates a number of authorities⁶ that have specific tasks mentioned in the draft. These authorities will also process personal data in the performance of their tasks.

Legislative assessment

1. Legal certainty

Cooperation and information exchange

Articles 52, first and second paragraphs, 53, 55, first paragraph, 56, and 57 of the draft stipulate, in summary, that the authorities mentioned in those articles must cooperate for the effective and efficient execution of their tasks and that they must exchange all necessary data, including personal data, among themselves. The tasks of the relevant authorities are regulated in Chapter 5 of the draft.

Special categories of personal data

Article 64a, second paragraph, of the draft states that the prohibition on processing special categories of personal data, in light of Article 9, second paragraph, introductory phrase and point g, GDPR, does not apply in the case of processing by the CSIRT (Computer Security Incident Response Team⁷) and

1 Directive (EU) 2022/2555 of the European Parliament and the Council of December 14, 2022, concerning measures for a high common level of cybersecurity in the Union, amending Regulation (EU) No. 910/2014 and Directive (EU) 2018/1972 and repealing Directive (EU) 2016/1148 (OJ EU 2022, L 333).

2 Articles 22 and 45 to 47 of the draft.

3 Article 23 of the draft.

4 Article 26 of the draft.

5 Articles 27 to 31 of the draft.

6 Namely, the central contact point (Article 15 of the draft), competent authorities (Article 16 of the draft), the CSIRT (Article 17 of the draft), coordinator for disclosing vulnerabilities (Article 18 of the draft), and the cyber crisis management authority (Article 19 of the draft).

7 Mentioned in Article 10 of the NIS2 directive.

Date

June 20, 2024

Our reference

z2024-013712

3/8

the competent authority insofar as that processing is necessary for the performance of their tasks under the Cybersecurity Act.

Confidential data

Article 65 of the draft regulates the possibility for the entities mentioned therein to provide confidential data to each other and to the authorities mentioned in the article under certain conditions.

An important requirement that also arises from the principle of proportionality and is mentioned in the recitals of the GDPR is that a legal basis or legislative measure for the processing of personal data (and thus an infringement of the right to the protection of personal data) must be sufficiently clear and precise, and that the application of that legal basis or legislative measure in practice must be predictable for those to whom it applies.

From the requirement that an interference with the exercise of the right to respect for private life and

the protection of personal data must be provided for by law, it follows that such interference must be based on a duly published legal provision from which the citizen can ascertain with sufficient precision which personal data may be collected and recorded for the purpose of fulfilling a specific government task, and under what conditions that data may be processed, stored, and used for that purpose. The regulation itself must therefore be sufficiently specific.

Merely mentioning examples of personal data that may be considered in the relevant regulation in the explanatory notes is not sufficient.

From the aforementioned articles regarding cooperation and information exchange, it is not clear which types of personal data may be exchanged. The draft also does not contain a basis for determining this in delegated legislation.

From Article 64a of the draft, it cannot be determined which categories of special personal data are involved. Although the second paragraph states that rules may be established by or under an order in council regarding the processing of special personal data; this is, however, not mandatorily prescribed.

Article 65 of the draft does not clarify what is meant by confidential data. This is also not defined elsewhere in the draft.

The AP concludes that the draft is not sufficiently clear and precise on the aforementioned points and that the application of the draft on these points is insufficiently predictable, so that adjustment of Articles 52, first and second paragraphs, 53, 55, first paragraph, 56, 57, 64a, and 65 of the legislative text is necessary by:

1. including in the legislative text a basis that mandatorily prescribes determining which types of personal data may be exchanged for the purpose of the cooperation referred to in Articles 52, first and second paragraphs, 53, 55, first paragraph, 56, and 57 of the draft;

Date

June 20, 2024

Our reference

z2024-013712

4/8

2. to formulate the second paragraph of Article 64a of the draft in imperative terms and also to prescribe therein that by means of a general administrative measure (amvb) it must be determined which categories of special personal data are necessary for the performance of the tasks of the CSIRT and the competent authority;

3. to define in the draft what is precisely meant by the term 'confidential data' or to include a basis in Article 65 of the draft that mandatorily prescribes determining which data this refers to in delegated legislation.

2. Retention Period

The draft lacks a provision regarding the retention period of personal data processed by the authorities designated in the draft for the purpose of carrying out their tasks. In paragraph 6.2.2.2 of the explanatory memorandum to the draft, it states that the Minister of Justice and Security will, in the context of her role as the central contact point, continuously assess whether it is necessary to retain the personal data received from the CSIRT for that purpose. Regarding the CSIRT and the competent authorities, the explanatory memorandum mentions that these authorities will not retain personal data longer than necessary for their tasks. According to the Data Protection Impact Assessment (hereinafter: DPIA) accompanying the draft, the current assumption is a retention period of 60 months after the incident has been resolved or the report of the incident has been made. This would align with the practice of reporting a cyber incident under the Act on the Security of Network and Information Systems (Wbni).

According to Article 5, paragraph 1, subparagraph e, of the General Data Protection Regulation (GDPR), personal data may not be retained in a form that allows the identification of data subjects for longer than is necessary for the purposes for which the personal data are processed. In this regard,

the data controller must establish a period for the deletion of data or for the periodic review thereof.

The GDPR stipulates that personal data may not be retained longer than is necessary for the purposes for which the personal data are processed. A general norm such as this means that it must be specified for specific data processing activities. The Dutch Data Protection Authority (AP) considers it desirable, from the perspective of legal certainty, that the legislator determines the retention period when making assessments in individual cases is not appropriate and a logical retention period does not clearly arise from the context.

Neither the draft nor the explanatory memorandum to the draft indicates whether, and if so, which retention periods have been established. The draft also does not provide for a delegation basis that would allow for the determination of retention periods in delegated legislation. According to the DPIA, a retention period of 60 months would be necessary, but this is not substantiated in the explanatory memorandum.

The AP concludes that it is advisable to include a retention period (possibly in the form of a maximum) regarding personal data processed by the authorities designated in the draft, either in the draft itself or in subordinate legislation, and to substantiate this in the explanatory memorandum.

8 Article 5, paragraph 1, subparagraph e, GDPR.

Date

June 20, 2024

Our reference

z2024-013712

5/8

explicit attention should be paid to the possibility of differentiated retention periods for the distinct tasks of the designated authorities.

3. International Transfer

In the article-by-article explanation of Article 55 of the draft, it is stated, among other things:

“If the information concerns data that also contains personal data, the CSIRT must, of course, comply with national and international rules regarding the transfer of personal data to third countries, including those of Article 49 of the General Data Protection Regulation. The examples mentioned above may then—when it concerns information that also contains personal data, such as login details or email files—serve as compelling reasons of general interest. After all, the general interest of the Netherlands requires that malicious infrastructure be disabled or that chains be safeguarded from malicious infections. The second paragraph of Article 55 of this bill aims to implement Article 10, eighth paragraph, of the NIS2 Directive and concerns the cooperation between the CSIRT and a national CSIRT or equivalent body of a third country.”

This seems to be based on Recital 45 of the NIS2 Directive, which, in short, states that the exchange of personal data with national CSIRTs or competent authorities of third countries is possible, provided that the conditions of Union data protection law regarding the transfer of personal data to third countries are met, including those of Article 49 GDPR.

In the context of the exchange of personal data with third countries, it is, however, primarily important to ascertain whether there is an adequacy decision, which can be utilized. If that is not the case, it must be determined whether there is a ground in Article 46 GDPR that can be utilized. This seems plausible, as the exchange will take place between public authorities within the Union and in third countries, and it is then possible that an administrative arrangement pursuant to Article 46, third paragraph, part b, GDPR or ad hoc contractual clauses as referred to in Article 46, third paragraph, part a, GDPR can be utilized. Only if none of these grounds apply can it be considered whether one of the exceptions for specific situations, to which Article 49 GDPR pertains, is applicable.

The AP concludes that the current text in the explanation of Article 55 of the draft may incorrectly give the impression that international transfer of personal data in the sense of that article must particularly

take place based on one of the exceptions in Article 49 GDPR. The explanation should include a clarification regarding the order of grounds for international transfer in accordance with what is stated in the previous paragraph.

4. Fine Authority of the AP

Article 52, second paragraph, introductory phrase and part b, of the draft states that the competent authority, the CSIRT, and the central contact point for the effective and efficient execution of their tasks

9 Article 45 GDPR.

10 See also the guidelines of the EDPB on Article 49 GDPR and on Article 46 (3)(b) GDPR.

Date

June 20, 2024

Our reference

z2024-013712

6/8

collaborate with, among others, the Data Protection Authority and that they exchange all necessary data, including personal data. Article 52, second paragraph, introductory phrase and subparagraph b, according to the transposition table, is an implementation of Article 35, second paragraph, NIS2 Directive. In that paragraph, it is, in summary, provided for a priority arrangement in the event that both a NIS2 supervisory authority and the supervisory authority referred to in the GDPR are competent to impose an administrative fine for the same conduct. Article 35, second paragraph, NIS2 Directive stipulates that in that case, the supervisory authority referred to in the GDPR takes precedence. This follows from the systematics of Article 35 of the NIS2 Directive. Article 35, first paragraph, of the NIS2 Directive concerns cases where there may also be a violation of provisions of the GDPR regarding the security of personal data. If that violation is such that, in the event of a data breach occurring, it would be reportable under the GDPR, the GDPR supervisory authority, in this case the AP, must be informed so that it can assess whether an administrative fine should be imposed under the GDPR. If the AP imposes an administrative fine for the relevant infringement, the NIS2 supervisory authority may not impose a fine for that part of the violation. This priority arrangement follows from Article 35, second paragraph, NIS2 Directive and must be implemented in national legislation.

Article 5:43 of the General Administrative Law Act (Awb) provides a general regulation for the situation where an administrative fine has already been imposed on the offender for the same violation. However, Article 5:43 Awb does not regulate which administrative body takes precedence in a particular case. Article 52, second paragraph, introductory phrase and subparagraph b, of the draft only stipulates that there must be cooperation between the NIS2 supervisory authorities and the Data Protection Authority if both are competent in the event of the same violation, but does not specify which authority takes precedence in imposing an administrative fine.

The AP concludes that Article 35, second paragraph, introductory phrase and subparagraph b, NIS2 Directive has not been correctly or fully implemented in the draft, making it necessary to supplement the legislative text and the explanation on this point.

Workload AP

The AP anticipates that the draft will necessitate additional efforts. The reason for this is that Article 59, second paragraph, of the draft¹¹ indicates that a competent authority, if it becomes aware during supervision or enforcement that a violation of Articles 23, 27, 28, 29, 30, 31, or 32 of the draft may involve a breach related to personal data that must be reported under Article 33 GDPR, must notify the AP. The anticipated additional efforts of the AP concern:

- a.
the establishment of a reporting point for NIS2 supervisory authorities;
- b.
the conducting of an initial assessment of the notification from the NIS2 supervisory authority;
- c.

in consultation with the NIS2 supervisory authority, coordinating and deciding to what extent the AP participates in an investigation into the facts; and

11 Implementation of Article 35, first paragraph, NIS2 Directive.

Date

June 20, 2024

Our reference

z2024-013712

7/8

d.

in consultation with the NIS2 supervisory authority, coordinating and deciding to what extent the AP, as the GDPR supervisory authority, wishes to exercise its right of precedence.

To determine the additional efforts required for the supervision of the AP, it is important that the AP is informed of the implementation and enforcement assessments (hereinafter: UHTs) of the NIS2 supervisory authorities. We therefore request a copy of these UHTs so that the AP can determine the implications for its activities. Based on these UHTs, the AP will independently prepare a UHT and send it to you.

The anticipated additional efforts of the AP for the aforementioned NIS2 tasks have not yet been accounted for in the funding of the AP. We assume that the Minister of Justice and Security or the Minister for Legal Protection will timely provide the necessary funding for the execution of the above tasks of the AP. A copy of this legislative assessment will be sent to the Minister for Legal Protection.

Publication

This legislative assessment will be published on the AP's website within two weeks.

Yours sincerely,

Data Protection Authority,

Aleid Wolfsen

Chairman

Date

June 20, 2024

Our reference

z2024-013712

8/8

- Annex

--*--

Assessment Framework AP

The AP examines whether the draft regarding the processing of personal data is in accordance with the Charter of Fundamental Rights of the European Union (EU), the GDPR (Regulation 2016/679), or the Police and Justice Directive (Directive 2016/680), the general legal principles of the EU, and other relevant law, whereby it must be sufficiently demonstrated that the principle of proportionality is met, by:

1. the draft being suitable for achieving the pursued objective of general interest or the protection of the rights and freedoms of others (suitability);
2. the objective cannot reasonably be achieved as effectively by other means that are less intrusive to the fundamental rights of the data subjects (subsidiarity);
3. the interference is not disproportionate to that objective, which particularly implies a balancing of the importance of the objective and the severity of the interference (proportionality);
4. the draft is sufficiently clear and precise regarding its scope and is predictable in its application

(legal certainty);

5. the draft sufficiently indicates under what circumstances and conditions personal data may be processed, thereby ensuring that the interference is limited to what is strictly necessary (substantive and procedural safeguards); and

6. the draft is binding under national law (bindingness under national law).

The AP pays particular attention to the rights of data subjects and the compliance of the draft with Article 6, paragraphs 1 and 3, and Article 9 of the GDPR (Regulation 2016/679), or Articles 8 and 10 of the Police and Justice Directive (Directive 2016/680), and with the principles established in Article 5 of the GDPR or Article 4 of the Directive. This implies, among other things, that:

(a) processing must be lawful, fair, and transparent with respect to the data subject;

(b) personal data may only be collected for specified, explicitly defined, and legitimate purposes; and

(c) processing must be adequate, relevant, and limited to what is necessary for the purposes.

--*--